MÒDUL 06 · SEGURETAT INFORMÀTICA — RA3 · NF3-AA1

Malware



Els sistemes informàtics també emmalalteixen

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar
Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



Tipus de malware

Virus, cucs, troians, backdoors, rootkits, spyware, ransomware: com es propaguen i què fan.



Eines antimalware

Com detecten el malware els antivirus: signatures, heurística i sandbox.



Eines de detecció online

VirusTotal i altres plataformes per comprovar fitxers sospitosos.

HO SABIES?

Els sistemes informàtics són com organismes vius

Malalties digitals

Podem pensar en els sistemes informàtics com a sistemes vius que poden patir "malalties": ciberatacs provocats per programari maliciós (malware) que compromet el seu funcionament i la seguretat de les dades.

Stuxnet (2010)

Malware compost que va afectar les centrals nuclears iranianes. Es va propagar per USB, després per xarxa local (com un cuc), fins arribar a l'equip crític, on una bomba lògica activava el dany. Un dels primers ciberatacs amb finalitat política i militar.

CLASSIFICACIÓ

Virus, cucs i troians

Tipus	Com actua
Virus	S'injecta en un programa legítim i es propaga quan aquest s'executa. Ataca executables, macros o sectors d'arrencada.
Cuc (worm)	Es propaga automàticament per la xarxa, SENSE interacció de l'usuari, explotant vulnerabilitats. Congestiona xarxes i és vehicle d'altres malware.
Troià	Es fa passar per un programa legítim per enganyar l'usuari perquè l'executi. NO es propaga automàticament: depèn de l'engany.

ACCÉS PERSISTENT I OCULT

Backdoors i rootkits



Backdoor

Permet a un atacant accedir remotament i sense autorització a un sistema. Pot ser instal·lat per un troià o creat deliberadament per un desenvolupador maliciós.



Rootkit

S'oculta dins del sistema operatiu per mantenir l'accés sense ser detectat: modifica el nucli, amaga processos i fitxers, intercepta crides al sistema.



Pegasus: malware tipus backdoor usat per espiar periodistes, activistes i polítics accedint a missatges, correus i trucades de smartphones.

LA GRAN AMENAÇA ACTUAL

Ransomware, spyware i adware

- Ransomware: segresta la informació xifrant-la i exigeix un rescat. Impacte catastròfic si no hi ha còpies de seguretat (o si també han estat xifrades).
- Spyware: recol·lecta i envia informació de l'usuari (els keyloggers, que capturen pulsacions de teclat, en són un exemple perillós).
- Adware: mostra anuncis molestos i pot redirigir el trànsit amb finalitats lucratives.



WannaCry (2017): l'atac de ransomware més devastador de la història, va infectar més de 230.000 ordinadors en 150 països.

UNA PART, NO UN TOT

Bombes lògiques

- No és un malware per si mateix, sinó una part d'un malware més complex que executa una acció destructiva quan es compleixen determinades condicions (una data, una acció de l'usuari...).
- A Stuxnet, la bomba lògica s'activava en detectar que el sistema infectat controlava centrifugadores d'enriquiment d'urani, provocant-hi una avaria.

DEFENSA

Com funcionen les eines antimalware



Protecció en temps real

Supervisa constantment el sistema per detectar i bloquejar activitat sospitosa abans que causi danys.



Anàlisi sota demanda

Permet a l'usuari escanejar el sistema manualment per detectar i eliminar malware ja instal·lat.

- Signatures: cerquen cadenes binàries característiques (el malware s'hi camufla amb polimorfisme).
- Heurística: detecta comportaments sospitosos (obrir connexions de xarxa, crides estranyes al SO...).
- Sandbox: executa programes sospitosos en un entorn aïllat per observar-ne l'efecte.
- Registre de hash dels fitxers del sistema, per detectar canvis no autoritzats.

A GRAN ESCALA

Solucions XDR/SIEM

En organitzacions grans és habitual un sistema centralitzat de protecció: SIEM (Security Information and Event Management) actua com a centre de control, i XDR (Extended Detection and Response) engloba les eines de detecció (antimalware, IDS/IPS, EDR) en equips, xarxa i correu.

- Permeten correlacionar esdeveniments de diverses fonts i generar alertes per a una resposta ràpida davant incidents de seguretat.

COMPROVACIÓ RÀPIDA

Eines online de detecció de malware

Eina	Ús
VirusTotal	La més popular: analitza un fitxer o URL amb desenes de motors antivirus a la vegada.
MetaDefender	Anàlisi multiescaner similar a VirusTotal.
Jotti / VirScan	Alternatives d'anàlisi multiescaner de fitxers.
AndroTotal	Especialitzat en aplicacions Android (APK).



Les mostres pujades a aquestes plataformes s'utilitzen per millorar els motors de detecció: no hi pugis mai fitxers confidencials.

PER ACABAR

Idees clau d'avui



Un ecosistema d'amenaces

Virus, cucs i troians es propaguen de manera diferent; backdoors i rootkits busquen persistir ocults.



Ransomware, l'amenaça #1

La indústria del cibercrim mou milers de milions de dòlars a través del segrest de dades.



Defensa en capes

Signatures + heurística + sandbox a l'equip, XDR/SIEM a nivell d'organització.

ARA ÉS EL TORN VOSTRE



Un company rep un correu amb un fitxer adjunt "Factura_pendent.pdf.exe" d'un remitent desconegut.

En parelles: identifiqueu quin tipus de malware sospiteu que podria ser i per quina via es propagaria si s'executa; proposeu 3 accions concretes (una preventiva, una de detecció i una de resposta) que hauria de prendre l'empresa.

10 minuts en parelles + posada en comú

FONTS DEL MATERIAL

Webgrafia

NF3-AA1: Malware

Repositori "Materials" (GitHub, SMX-0226SI) · Carlos Alonso Martínez, Escola Pia de Mataró · Llicència CC-BY-SA-4.0

Kaspersky — Tipos de malware y ejemplos

kaspersky.es/resource-center/threats/types-of-malware

INCIBE — Ransomware: guía de aproximación al empresario

incibe.es/empresas/guias/ransomware-guia-aproximacion-el-empresario

VirusTotal

virustotal.com

Llicència CC BY-SA 4.0 · Adaptat de "Materials" (SMX-0226SI), Carlos Alonso Martínez, Escola Pia de Mataró